Homestay Management System – Tài liệu BA (Phần 2: Nền tảng, dữ liệu chủ & bảo mật)

Oct 31, 2026 · @Hữu Chan

0. Thông tin tài liệu

Phần 2 đặc tả chi tiết đợt 1 của kế hoạch BA: 6 module nền tảng (CFG, PROP, ROOM, RBAC, EMP, AUD khung), Role & Permission Matrix, Data Dictionary và NFR bảo mật. Tài liệu chỉ tham chiếu BR, OQ, NFR đã định nghĩa ở Phần 1 v0.2, không định nghĩa lại.

Thuộc tính	Giá trị
Phiên bản	v0.1 – Draft, viết trước workshop đợt 0
Căn cứ	Phần 1 v0.2 (31/10/2026) và tab "Rà soát lỗ hổng"
Trạng thái baseline	Chưa baseline: 12 OQ Blocking chưa được trả lời
Người đọc	PO, UI/UX, Dev Lead, QA Lead, System Admin

0.1 Giả định áp dụng

Vì chưa có workshop, đợt 1 được viết trên các ASM của Phần 1. Yêu cầu phụ thuộc ASM của câu Blocking mang nhãn [Q] và chưa được chốt.

ASM	Nội dung	Ảnh hưởng trong Phần 2	Nhãn
ASM-001	Bán phòng riêng và cả căn; dữ liệu hỗ trợ cả giường	FR-ROOM-003, FR-ROOM-004	[Q]
ASM-032	Một chủ, nhiều cơ sở; kiến trúc sẵn sàng tenant_id	FR-RBAC-003, NFR-SEC mục 9	[Q]
ASM-037	Chưa giả định hình thức pháp lý; hệ thống lưu cả hai loại	FR-PROP-001	[Q]
ASM-040	Duyệt từ xa có 2FA; Owner được tự duyệt có lý do	FR-RBAC-005 đến FR-RBAC-007	[A]
ASM-036	PostgreSQL	Data Dictionary, FR-RBAC-003	[A]

ASM	Nội dung	Ảnh hưởng trong Phần 2	Nhãn
ASM-019	Lưu 5 năm, ẩn danh hoá khi có yêu cầu	FR-AUD-007, FR-EMP-008	[Q]

0.2 Vai trò hệ thống

Chín vai trò cố định trong MVP, ánh xạ từ Stakeholder Matrix (Phần 1, mục 4). Một người có thể giữ nhiều vai trò ở nhiều cơ sở.

Mã	Vai trò	Phạm vi	Stakeholder
R-OWN	Chủ / Owner	Toàn chuỗi	SH-01
R-MGR	Quản lý cơ sở	Cơ sở được gán	SH-02
R-FD	Lễ tân	Cơ sở được gán	SH-03
R-NA	Lễ tân ca đêm / Night Auditor	Cơ sở được gán	SH-12
R-ACC	Kế toán / Thu ngân	Cơ sở được gán hoặc toàn chuỗi	SH-04
R-HKS	Giám sát buồng phòng	Cơ sở được gán	SH-11
R-HK	Nhân viên buồng phòng	Cơ sở được gán	SH-05
R-MNT	Kỹ thuật / Bảo trì	Cơ sở được gán	SH-06
R-ADM	Quản trị hệ thống	Toàn chuỗi, không có quyền nghiệp vụ tiền	SH-07

0.3 Cách đọc

Mỗi module có 11 mục theo khung Phần 1 (11.2). Quy ước bổ sung:

- **Ưu tiên** theo MoSCoW: M (Must), S (Should), C (Could). **Phase** 1 = MVP.
- **Mã lỗi** ERR-<MODULE>-xxx dùng chung cho UI, API và test case.
- **AC** viết dạng Given / When / Then; mỗi AC có ít nhất một TC.
- BR và OQ mới phát sinh ở Phần 2 được gom ở mục 10 để đưa ngược vào Phần 1.

1. Module CFG – Cấu hình hệ thống

CFG là nơi duy nhất giữ tham số vận hành; mọi module khác chỉ đọc. Tham số ảnh hưởng tiền (thuế, chế độ giá, làm tròn) có ngày hiệu lực và không bao giờ áp hồi tố (BR-009 đề xuất).

1.1 Mục tiêu và actor

- **Mục tiêu**: thay đổi quy tắc vận hành mà không cần sửa code, không làm sai số liệu quá khứ. Phục vụ BG-02, BG-07, BG-08.
- **Actor**: R-OWN sửa tham số tài chính; R-MGR sửa tham số vận hành của cơ sở mình; R-ADM sửa mẫu in, đánh số, tham số kỹ thuật; vai trò khác chỉ đọc phần cần cho công việc.
- **Cơ chế kế thừa**: mỗi tham số có giá trị cấp chuỗi; cơ sở có thể ghi đè. Màn hình luôn hiển thị nguồn giá trị (kế thừa hay ghi đè).

1.2 Yêu cầu chức năng

ID	Yêu cầu	Ưu tiên	Phase	BR / NFR
FR-CFG-001	Quản lý tham số cấp chuỗi và ghi đè cấp cơ sở; hiển thị nguồn giá trị; cho phép trở về kế thừa	M	1	BR-060
FR-CFG-002	Giờ check-in/out chuẩn, bậc early/late, giờ cắt no-show, múi giờ hiển thị	M	1	BR-005, BR-006, BR-007, BR-032
FR-CFG-003	Hạn giữ phòng và hạn cọc mặc định theo kênh	M	1	BR-012
FR-CFG-004	Chế độ giá gồm/chưa gồm thuế theo cơ sở; danh mục TaxRule theo loại dòng phí, có hiệu lực từ–đến, không chồng khoảng	M	1	BR-024, BR-009
FR-CFG-005	Quy tắc làm tròn: đơn vị (1 / 100 / 1.000 đồng), cách làm tròn, dòng nhận phần dư	M	1	BR-026

ID	Yêu cầu	Ưu tiên	Phase	BR / NFR
FR-CFG-006	Đánh số chứng từ theo mẫu (booking nội bộ, phiếu thu, hoá đơn): không trùng, không tái dùng, không nhảy số khi giao dịch lỗi; mã booking ngoài ngẫu nhiên	M	1	BR-074
FR-CFG-007	Danh mục mã lý do theo nhóm; mã đã dùng chỉ được ngưng, không xoá	M	1	BR-021, BR-040
FR-CFG-008	Danh mục dịch vụ (ServiceItem): tên, đơn giá, đơn vị, loại thuế; dùng cho minibar và đền bù	M	1	BR-022
FR-CFG-009	Mẫu in và mẫu tin nhắn (VN/EN) với danh sách biến được phép; biến luôn được escape	S	1	NFR-SEC-005, NFR-I18N-001
FR-CFG-010	Trạng thái buồng tối thiểu để check-in (Clean / Inspected); bật/tắt bước Inspected	M	1	BR-051
FR-CFG-011	Lịch sử thay đổi cấu hình; xem giá trị hiệu lực tại một ngày bất kỳ	M	1	BR-061
FR-CFG-012	Sửa tham số tài chính yêu cầu xác thực lại (mật khẩu + 2FA)	M	1	NFR-SEC-001

1.3 Business rules áp dụng

BR-005, BR-006, BR-007, BR-012, BR-024, BR-026, BR-051, BR-061, BR-074 (Phần 1) và **BR-009 đề xuất**: tham số ảnh hưởng tiền có ngày hiệu lực ≥ business date + 1; giao dịch đã ghi không tính lại; thuế của một dòng phí lấy theo TaxRule hiệu lực tại business date ghi dòng đó.

1.4 Luồng chính – UC-CFG-001 Đổi thuế suất có hiệu lực tương lai

1. R-OWN mở TaxRule của loại dòng "tiền phòng", chọn Tạo hiệu lực mới.
2. Nhập thuế suất mới và ngày hiệu lực. Hệ thống kiểm tra ngày ≥ business date + 1 và không chồng khoảng.
3. Hệ thống hiển thị tác động: số booking có đêm lưu trú từ ngày hiệu lực và tổng thuế dự kiến thay đổi.
4. R-OWN xác thực lại (mật khẩu + 2FA) và xác nhận.

5. Hệ thống đóng khoảng hiệu lực cũ vào ngày trước, lưu khoảng mới, ghi audit, thông báo R-MGR và R-ACC của các cơ sở bị ảnh hưởng.

1.5 Luồng thay thế

- **A1 – Ghi đè cấp cơ sở**: R-MGR đổi giờ check-in của cơ sở mình; cơ sở khác vẫn kế thừa.
- **A2 – Trở về kế thừa**: xoá giá trị ghi đè; lịch sử vẫn giữ.
- **A3 – Huỷ thay đổi chưa hiệu lực**: thay đổi có ngày hiệu lực tương lai được huỷ trước ngày đó, có audit.

1.6 Xử lý ngoại lệ

Mã	Tình huống	Thông điệp / hành vi
ERR-CFG-001	Ngày hiệu lực ⩽ business date của cơ sở	"Ngày hiệu lực phải sau ngày nghiệp vụ hiện tại"; không lưu
ERR-CFG-002	Khoảng hiệu lực TaxRule chồng nhau	Hiển thị khoảng bị chồng; không lưu
ERR-CFG-003	Đổi chế độ giá gồm/chưa gồm thuế khi còn booking Confirmed tương lai	Cảnh báo số booking; booking cũ giữ chế độ trong snapshot, booking mới dùng chế độ mới
ERR-CFG-004	Mẫu chứa biến không có trong danh sách	Chỉ ra biến sai; không lưu
ERR-CFG-005	Hai người sửa cùng tham số (version lệch)	"Cấu hình vừa được người khác thay đổi"; tải lại, không ghi đè
ERR-CFG-006	Xoá mã lý do hoặc dịch vụ đã dùng	Chỉ cho Ngưng
ERR-CFG-007	Xác thực lại thất bại	Không lưu; tính vào số lần sai của tài khoản (FR-EMP-003)

1.7 Dữ liệu và trạng thái

Entity: SystemParameter, TaxRule, ReasonCode, ServiceItem, NumberSequence, Template (chi tiết ở mục 8). Tham số có hiệu lực theo ngày đi qua 3 trạng thái: **Scheduled** (chưa tới ngày) → **Active** → **Superseded** (bị khoảng mới thay). Scheduled có thể chuyển **Cancelled**. ReasonCode và ServiceItem: Active ↔ Inactive.

1.8 Phụ thuộc

Đọc bởi mọi module. Phụ thuộc RBAC (quyền), EMP (xác thực lại), AUD (log), PROP (business date của cơ sở). Thay đổi chế độ thuế và làm tròn ảnh hưởng INV, RATE ở đợt 2–3.

1.9 User story và tiêu chí nghiệm thu

US-CFG-001 – Là Owner, tôi muốn đặt thuế suất mới có hiệu lực từ một ngày tương lai, để hoá đơn đã và đang phát sinh không bị sai.

- **AC-CFG-001-01** Given thuế tiền phòng 8% và business date 31/10; When Owner tạo thuế 10% hiệu lực từ 01/11 và xác thực lại thành công; Then dòng phí ghi vào business date 31/10 dùng 8%, dòng ghi từ 01/11 dùng 10%, và có một bản ghi audit có giá trị trước/sau.
- **AC-CFG-001-02** Given business date 31/10; When Owner chọn ngày hiệu lực 31/10 hoặc sớm hơn; Then hệ thống từ chối với ERR-CFG-001.
- **AC-CFG-001-03** Given có 12 booking có đêm từ 01/11; When Owner xem bước xác nhận; Then màn hình hiển thị "12 booking bị ảnh hưởng".

US-CFG-002 – Là Manager, tôi muốn chỉnh giờ check-in của cơ sở mình mà không ảnh hưởng cơ sở khác.

- **AC-CFG-002-01** Given giờ check-in cấp chuỗi 14:00; When Manager cơ sở A đặt 13:00; Then cơ sở A hiển thị 13:00 (ghi đè), cơ sở B hiển thị 14:00 (kế thừa).
- **AC-CFG-002-02** Given Manager chỉ được gán cơ sở A; When gọi API sửa tham số của cơ sở B; Then hệ thống trả về "không tìm thấy" (ERR-RBAC-001), không thay đổi dữ liệu.

US-CFG-003 – Là Admin, tôi muốn mã lý do đã dùng không bị xoá, để báo cáo cũ vẫn đọc được.

- **AC-CFG-003-01** Given mã "PHONG_HONG" đã được dùng; When Admin chọn Xoá; Then hệ thống chỉ cho Ngưng (ERR-CFG-006); mã ngưng không xuất hiện khi chọn mới nhưng vẫn hiển thị trên bản ghi cũ.

US-CFG-004 – Là Admin, tôi muốn số phiếu thu liên tục và không trùng, để kế toán đối chiếu được.

- **AC-CFG-004-01** Given 20 phiếu thu được tạo đồng thời ở cùng cơ sở; When tất cả hoàn thành; Then 20 số khác nhau, liên tục; giao dịch bị lỗi không tiêu số.

1.10 Test case

TC	Kiểm tra	AC	Loại
TC-CFG-001	Thuế theo business date của dòng phí trước/sau ngày hiệu lực	AC-CFG-001-01	Chức năng
TC-CFG-002	Từ chối ngày hiệu lực quá khứ và bằng business date	AC-CFG-001-02	Biên
TC-CFG-003	Đếm booking bị ảnh hưởng	AC-CFG-001-03	Chức năng
TC-CFG-004	Ghi đè / kế thừa theo cơ sở	AC-CFG-002-01	Chức năng
TC-CFG-005	Sửa tham số cơ sở khác qua API	AC-CFG-002-02	Bảo mật
TC-CFG-006	Xoá mã lý do đã dùng	AC-CFG-003-01	Chức năng
TC-CFG-007	Cấp số đồng thời 20 phiếu, có 1 giao dịch lỗi	AC-CFG-004-01	Đồng thời

1.11 Self-review

- **Thiếu rule về hiệu lực cấu hình** → đề xuất BR-009 (mục 10).
- **Đánh số không nhảy số** mâu thuẫn với hiệu năng khi cấp số đồng thời; chấp nhận khoá tuần tự theo (cơ sở, loại chứng từ) vì lưu lượng homestay thấp. Nếu kế toán chấp nhận nhảy số thì nới lỏng – OQ-046.
- **Quy định đánh số hoá đơn** có thể do nhà cung cấp hoá đơn điện tử cấp, không do HMS – phụ thuộc OQ-015, ghi [Q] cho phần hoá đơn của FR-CFG-006.

2. Module PROP – Quản lý cơ sở

Mỗi cơ sở có vòng đời 4 trạng thái; chỉ cơ sở Active mới nhận booking mới, và cơ sở chỉ được đóng khi không còn booking tương lai và folio mở.

2.1 Mục tiêu và actor

- **Mục tiêu**: là gốc phân vùng dữ liệu (BR-060), giữ thông tin pháp lý để xuất chứng từ và business date để ghi nhận doanh thu. Phục vụ BG-06, BG-08.

- **Actor**: R-OWN tạo, kích hoạt, tạm ngưng, đóng; R-MGR sửa thông tin vận hành của cơ sở mình (không sửa thông tin pháp lý); vai trò khác chỉ đọc.

2.2 Yêu cầu chức năng

ID	Yêu cầu	Ưu tiên	Phase	BR / OQ
FR-PROP-001	Tạo cơ sở: mã duy nhất trong chuỗi, tên, địa chỉ, múi giờ, hotline, hình thức pháp lý (hộ kinh doanh / doanh nghiệp), mã số thuế, thông tin người bán trên chứng từ	M	1	[Q] OQ-037
FR-PROP-002	Vòng đời Draft → Active → Suspended → Closed với điều kiện ở 2.7	M	1	BR-016
FR-PROP-003	Khi kích hoạt, khởi tạo business date đầu tiên (BusinessDay = Open) theo ngày địa phương	M	1	BR-004, BR-008
FR-PROP-004	Kiểm tra cấu hình bắt buộc trước khi kích hoạt và liệt kê mục còn thiếu	M	1	–
FR-PROP-005	Thông tin hiển thị cho khách (tên, địa chỉ, bản đồ, hotline, nội quy) dùng trong mẫu tin và xác nhận	M	1	FR-CFG-009
FR-PROP-006	Sao chép cấu hình cơ sở (tham số, loại phòng, mẫu) sang cơ sở mới ở trạng thái Draft	S	1	–
FR-PROP-007	Múi giờ chỉ được đổi khi cơ sở còn Draft	M	1	BR-007
FR-PROP-008	Danh sách cơ sở chỉ hiển thị cơ sở người dùng được gán; Owner thấy tất cả	M	1	BR-060

2.3 Business rules áp dụng

BR-004, BR-007, BR-008, BR-016, BR-060, BR-061 (Phần 1). Không có BR mới.

2.4 Luồng chính – UC-PROP-001 Tạo và kích hoạt cơ sở

1. R-OWN tạo cơ sở mới (hoặc sao chép từ cơ sở có sẵn); cơ sở ở trạng thái Draft.
2. R-OWN hoặc R-MGR được gán khai báo loại phòng, phòng (module ROOM) và tham số (CFG).

3. R-OWN chọn Kích hoạt. Hệ thống kiểm tra: có thông tin pháp lý, múi giờ, ít nhất 1 phòng đang bán, chế độ thuế, ít nhất 1 người dùng có vai trò R-MGR hoặc R-FD.
4. Đủ điều kiện: cơ sở chuyển Active, tạo BusinessDay đầu tiên, khởi tạo RoomTypeInventory (FR-ROOM-004), ghi audit.

2.5 Luồng thay thế

- **A1 – Tạm ngưng (sửa chữa, hết mùa)**: Active → Suspended, bắt buộc lý do; chặn tạo booking mới, booking hiện có vẫn check-in/out bình thường; Night Audit vẫn chạy.
- **A2 – Hoạt động lại**: Suspended → Active.
- **A3 – Đóng vĩnh viễn**: Active hoặc Suspended → Closed khi không còn booking tương lai, không còn folio mở; dữ liệu chuyển chỉ đọc. Công nợ còn lại chuyển về cấp chuỗi.

2.6 Xử lý ngoại lệ

Mã	Tình huống	Thông điệp / hành vi
ERR-PROP-001	Mã cơ sở trùng	"Mã cơ sở đã tồn tại"; không lưu
ERR-PROP-002	Kích hoạt khi thiếu cấu hình	Danh sách mục thiếu, mỗi mục có liên kết tới màn hình cần sửa
ERR-PROP-003	Đóng khi còn booking tương lai hoặc folio mở	Danh sách booking/folio cần xử lý; không đóng
ERR-PROP-004	Đổi múi giờ khi cơ sở không còn Draft	Khóa trường; hướng dẫn tạo cơ sở mới nếu thực sự cần
ERR-PROP-005	Tạo booking vào cơ sở Suspended/Closed	"Cơ sở đang tạm ngưng nhận đặt phòng"
ERR-PROP-006	R-MGR sửa thông tin pháp lý	Trường chỉ đọc; API trả ERR-RBAC-001

2.7 Dữ liệu và trạng thái

Entity: Property, BusinessDay (mục 8).

Chuyển trạng thái	Điều kiện	Actor
(mới) → Draft	Mã duy nhất	R-OWN
Draft → Active	Đủ cấu hình bắt buộc (FR-PROP-004)	R-OWN

Chuyển trạng thái	Điều kiện	Actor
Active → Suspended	Lý do bắt buộc	R-OWN
Suspended → Active	–	R-OWN
Active / Suspended → Closed	0 booking tương lai, 0 folio mở, xác thực lại	R-OWN
Draft → (xoá)	Chưa từng Active, không có giao dịch	R-OWN

2.8 Phụ thuộc

CFG (tham số), ROOM (điều kiện kích hoạt), RBAC (người dùng được gán), FO-NA (business date). Mọi module nghiệp vụ kiểm tra trạng thái cơ sở trước khi tạo booking.

2.9 User story và tiêu chí nghiệm thu

US-PROP-001 – Là Owner, tôi muốn mở một cơ sở mới bằng cách sao chép cơ sở hiện có, để không phải cấu hình lại từ đầu.

- **AC-PROP-001-01** Given cơ sở A Active có 3 loại phòng; When Owner sao chép sang cơ sở mới B; Then B ở Draft, có 3 loại phòng và tham số giống A, không có phòng, booking hay người dùng của A.
- **AC-PROP-001-02** Given B ở Draft chưa có phòng; When Owner kích hoạt; Then hệ thống từ chối (ERR-PROP-002) và liệt kê "Chưa có phòng đang bán".
- **AC-PROP-001-03** Given B đủ cấu hình, giờ địa phương 31/10 10:00; When Owner kích hoạt; Then B Active với business date 31/10 trạng thái Open.

US-PROP-002 – Là Owner, tôi muốn tạm ngưng nhận đặt phòng khi sửa chữa mà vẫn phục vụ khách đang ở.

- **AC-PROP-002-01** Given cơ sở A có 2 booking In-house; When Owner chuyển A sang Suspended với lý do; Then tạo booking mới bị từ chối (ERR-PROP-005), 2 booking In-house vẫn check-out được.
- **AC-PROP-002-02** Given A còn 1 booking Confirmed ngày 15/11; When Owner chọn Đóng; Then hệ thống từ chối (ERR-PROP-003) và hiển thị booking đó.

2.10 Test case

TC	Kiểm tra	AC	Loại
TC-PROP-001	Sao chép cơ sở không mang theo phòng, booking, người dùng	AC-PROP-001-01	Chức năng

TC	Kiểm tra	AC	Loại
TC-PROP-002	Kích hoạt thiếu từng điều kiện (4 trường hợp)	AC-PROP-001-02	Biên
TC-PROP-003	Business date đầu tiên theo múi giờ cơ sở	AC-PROP-001-03	Chức năng
TC-PROP-004	Suspended chặn booking mới, không chặn check-out	AC-PROP-002-01	Chức năng
TC-PROP-005	Đóng cơ sở còn booking tương lai / folio mở	AC-PROP-002-02	Chức năng
TC-PROP-006	Manager sửa mã số thuế qua API	– (ERR-PROP-006)	Bảo mật

2.11 Self-review

- **Suspended với kênh OTA**: khi CHN có ở Phase 2, Suspended phải tự stop-sell trên mọi kênh; ghi chú cho đợt 4.
- **Thông tin pháp lý** phụ thuộc OQ-037; FR-PROP-001 giữ nhãn [Q] cho trường liên quan hoá đơn.
- **Không phát hiện mâu thuẫn** với BR của Phần 1.

3. Module ROOM – Loại phòng, phòng, cấu trúc cha–con

ROOM là nguồn của tồn phòng: mọi thay đổi phòng hoặc loại phòng cập nhật sức chứa trong RoomTypeInventory trong cùng giao dịch, và bị từ chối nếu làm sức chứa thấp hơn số đã bán.

3.1 Mục tiêu và actor

- **Mục tiêu**: mô tả đúng đơn vị bán để chống trùng phòng (BG-01) và tính đúng phòng sẵn sàng bán (7.5 Phần 1).
- **Actor**: R-OWN, R-MGR (cơ sở mình) tạo, sửa, ngưng bán; R-ADM nhập hàng loạt khi go-live; vai trò khác chỉ đọc.
- **Khái niệm**: *loại phòng* là đơn vị bán và định giá; *phòng* là đơn vị vật lý với kind = room / unit (cả căn) / bed; *sức chứa tồn* của loại phòng tại một đêm = số phòng thuộc loại đó đang ở trạng thái bán tại đêm đó.

3.2 Yêu cầu chức năng

ID	Yêu cầu	Ưu tiên	Phase	BR / OQ
FR-ROOM-001	Loại phòng: tên, mã, sức chứa chuẩn, sức chứa tối đa, số giường phụ tối đa, mô tả VN/EN, ảnh, tiện nghi, cờ đang bán	M	1	BR-017
FR-ROOM-002	Phòng: số phòng duy nhất trong cơ sở, toà/tầng, loại phòng, kind, phòng cha, ghi chú nội bộ	M	1	–
FR-ROOM-003	Cấu trúc cha–con: unit chứa room, room chứa bed; tối đa 2 cấp, không vòng, cùng cơ sở	M (dữ liệu)	1; bán ở Phase 2–3	[Q] BR-018, OQ-001
FR-ROOM-004	Duy trì RoomTypeInventory cho cửa sổ tương lai cấu hình (mặc định 400 ngày): tạo khi kích hoạt cơ sở, tự mở rộng mỗi ngày, cập nhật capacity khi thêm/ngưng/đổi loại phòng	M	1	BR-013
FR-ROOM-005	Ngưng bán phòng hoặc loại phòng từ một ngày; từ chối nếu sau ngày đó còn RoomNight hoặc làm capacity < sold; hiển thị danh sách booking cần dời	M	1	BR-016
FR-ROOM-006	Đổi loại phòng của một phòng từ một ngày, với cùng kiểm tra như FR-ROOM-005 cho loại cũ	M	1	BR-013, BR-016
FR-ROOM-007	Nhập hàng loạt loại phòng và phòng từ file mẫu; kiểm tra toàn bộ trước khi ghi, lỗi một dòng thì không ghi dòng nào	S	1	Phần 1 mục 10.3
FR-ROOM-008	Danh mục tiện nghi dùng chung chuỗi	C	1	–
FR-ROOM-009	Không xoá cứng phòng/loại phòng đã có booking; chỉ ngưng bán	M	1	BR-062

3.3 Business rules áp dụng

BR-013, BR-016, BR-017, BR-018 (Phần 1) và **BR-019 đề xuất**: phòng có cha hoặc có con phải được gán ngay khi giữ tồn (không giữ dạng chưa gán); khi giữ, hệ thống cập nhật bộ đếm của mọi loại phòng bị ảnh hưởng (loại của cha và của từng con) trong cùng giao dịch. Lý do: nếu để chưa gán thì bộ đếm theo loại không biết cần trừ phòng con nào.

3.4 Luồng chính – UC-ROOM-001 Thêm phòng

1. R-MGR chọn loại phòng, nhập số phòng, toà/tầng, kind, phòng cha (nếu có) và ngày bắt đầu bán.
2. Hệ thống kiểm tra số phòng duy nhất, cấu trúc cha–con hợp lệ.
3. Hệ thống lưu phòng và cộng 1 vào capacity của loại phòng cho mọi đêm từ ngày bắt đầu bán, trong cùng giao dịch.
4. Phòng mới có trạng thái buồng Dirty (cần dọn trước lần bán đầu) và Vacant; ghi audit.

3.5 Luồng thay thế – UC-ROOM-002 Ngưng bán phòng

1. R-MGR chọn phòng, ngày ngưng bán và mã lý do.
2. Hệ thống tìm RoomNight hiệu lực của phòng từ ngày đó và các đêm mà capacity − 1 < sold.
3. Nếu có: hiển thị danh sách booking cần dời hoặc đêm bị thiếu chỗ, không lưu (ERR-ROOM-003, ERR-ROOM-004).
4. Nếu không: lưu, trừ 1 khỏi capacity từ ngày ngưng, ghi audit.

Ngưng bán khác khoá OOO: OOO là tạm thời, có khoảng ngày và đi qua MNT; ngưng bán là thay đổi danh mục, không có ngày kết thúc.

3.6 Xử lý ngoại lệ

Mã	Tình huống	Thông điệp / hành vi
ERR-ROOM-001	Số phòng trùng trong cơ sở	"Phòng 101 đã tồn tại"
ERR-ROOM-002	Sức chứa tối đa < sức chứa chuẩn, hoặc bằng 0	Không lưu
ERR-ROOM-003	Ngưng bán / đổi loại khi phòng còn RoomNight tương lai	Danh sách booking cần dời
ERR-ROOM-004	Thay đổi làm capacity < sold ở bất kỳ đêm nào	Danh sách đêm và số phòng thiếu

Mã	Tình huống	Thông điệp / hành vi
ERR-ROOM-005	Cấu trúc cha–con sai: vòng, quá 2 cấp, khác cơ sở, bed làm cha	Không lưu, chỉ ra quan hệ sai
ERR-ROOM-006	Đổi phòng cha khi cha hoặc con còn RoomNight tương lai	Không lưu
ERR-ROOM-007	File nhập hàng loạt có dòng lỗi	Báo cáo lỗi từng dòng; không ghi dòng nào
ERR-ROOM-008	Booking có đêm ngoài cửa sổ tồn	Hệ thống tạo dòng RoomTypeInventory còn thiếu trước khi kiểm tra, không coi là hết phòng

3.7 Dữ liệu và trạng thái

Entity: RoomType, Room, Amenity, RoomTypeInventory (mục 8). Trạng thái danh mục của phòng: **Active** (đang bán từ ngày X) → **Inactive** (ngưng bán từ ngày Y) → Active (bán lại). Trạng thái vận hành (Vacant/Occupied, Dirty/Clean…) thuộc HK và FO, không thuộc ROOM.

3.8 Phụ thuộc

PROP (cơ sở), CFG (cửa sổ tồn), AUD. Cung cấp cho BOOK, CAL, RATE, HK, MNT, CHN. RoomTypeInventory được BOOK cập nhật cột sold; ROOM chỉ cập nhật cột capacity.

3.9 User story và tiêu chí nghiệm thu

US-ROOM-001 – Là Manager, tôi muốn thêm phòng mới và phòng đó có thể bán ngay từ ngày tôi chọn.

- **AC-ROOM-001-01** Given loại Deluxe có 4 phòng; When Manager thêm phòng 105 loại Deluxe bán từ 05/11; Then capacity Deluxe là 4 cho đêm 04/11 và 5 cho đêm 05/11 trở đi.
- **AC-ROOM-001-02** Given đã có phòng 101; When thêm phòng 101 trong cùng cơ sở; Then từ chối ERR-ROOM-001.

US-ROOM-002 – Là Manager, tôi muốn ngưng bán một phòng mà không làm hỏng các booking đã nhận.

- **AC-ROOM-002-01** Given Deluxe có 5 phòng, đêm 20/11 đã bán 5 (2 gán phòng, 3 chưa gán), phòng 105 không có booking gán; When Manager ngưng bán 105 từ 15/11; Then từ chối ERR-ROOM-004 và báo "Đêm 20/11 thiếu 1 phòng".
- **AC-ROOM-002-02** Given phòng 105 có RoomNight đêm 18/11; When ngưng bán từ 15/11; Then từ chối ERR-ROOM-003 và hiển thị booking gán phòng 105 đêm 18/11.

US-ROOM-003 – Là Owner, tôi muốn khai báo villa 3 phòng ngủ để sau này bán cả căn hoặc từng phòng. [Q]

- **AC-ROOM-003-01** Given villa V1 kind unit; When thêm phòng V1-A, V1-B, V1-C với cha V1; Then cấu trúc được lưu và hiển thị dạng cây.
- **AC-ROOM-003-02** Given V1-A là con của V1; When đặt V1 làm con của V1-A; Then từ chối ERR-ROOM-005 (vòng).

3.10 Test case

TC	Kiểm tra	AC	Loại
TC-ROOM-001	Capacity theo ngày bắt đầu bán	AC-ROOM-001-01	Chức năng
TC-ROOM-002	Trùng số phòng cùng cơ sở; cho phép trùng giữa cơ sở khác nhau	AC-ROOM-001-02	Biên
TC-ROOM-003	Ngưng bán làm capacity < sold (có booking chưa gán)	AC-ROOM-002-01	Chức năng
TC-ROOM-004	Ngưng bán phòng có RoomNight tương lai	AC-ROOM-002-02	Chức năng
TC-ROOM-005	Ngưng bán đồng thời với tạo booking cùng loại phòng	AC-ROOM-002-01	Đồng thời
TC-ROOM-006	Cấu trúc cha–con: vòng, 3 cấp, khác cơ sở	AC-ROOM-003-02	Biên
TC-ROOM-007	Nhập file 50 dòng có 1 dòng lỗi	– (ERR-ROOM-007)	Chức năng

3.11 Self-review

- **Phát hiện lỗ hổng**: BR-013 cho giữ tồn chưa gán phòng, nhưng với phòng cha–con thì không xác định được phòng con nào bị chiếm → đề xuất BR-019.
- **Phát hiện lỗ hổng**: cửa sổ tồn giới hạn có thể khiến booking xa bị báo hết phòng sai → xử lý ở ERR-ROOM-008.
- **Đồng thời**: ngưng bán và tạo booking cùng lúc được chặn bởi CHECK sold ⩽ capacity của BR-013; cần TC-ROOM-005.
- **[Q]**: FR-ROOM-003 chờ OQ-001; nếu chủ không bán cả căn/giường thì giữ cột parent_id nhưng ẩn giao diện.

4. Module RBAC – Vai trò, quyền, luồng duyệt

RBAC trả lời ba câu: ai được làm gì, ở cơ sở nào, và thao tác nào cần người thứ hai duyệt. Mọi kiểm tra quyền chạy ở server; giao diện ẩn nút chỉ là tiện ích.

4.1 Mục tiêu và actor

- **Mục tiêu**: chặn truy cập chéo cơ sở, leo thang quyền và gian lận tiền (SEC-01 đến SEC-10 của báo cáo rà soát). Phục vụ BG-07.
- **Actor**: R-OWN quản trị toàn bộ; R-ADM gán vai trò không có quyền tiền; R-MGR gán vai trò trong cơ sở mình và duyệt; mọi vai trò có thể tạo yêu cầu duyệt.
- **Mô hình**: quyền hiệu lực của một người tại một cơ sở = hợp quyền của mọi vai trò họ được gán tại cơ sở đó và vai trò cấp chuỗi. Ngưỡng lấy mức cao nhất trong các vai trò.

4.2 Yêu cầu chức năng

ID	Yêu cầu	Ưu tiên	Phase	BR / NFR
FR-RBAC-001	9 vai trò hệ thống với bộ quyền mặc định (mục 7); MVP không tạo vai trò tuỳ biến, chỉ chỉnh ngưỡng	M	1	–
FR-RBAC-002	Gán/gỡ vai trò theo (người dùng, cơ sở); R-OWN và R-ADM là vai trò cấp chuỗi	M	1	BR-060
FR-RBAC-003	Lọc dữ liệu theo cơ sở (và tenant) ở tầng truy cập dữ liệu cho mọi truy vấn, API, báo cáo, file xuất; đối tượng thuộc cơ sở không được gán trả về như không tồn tại	M	1	BR-060, NFR-SEC-002, [Q] ASM-032
FR-RBAC-004	Ngưỡng theo vai trò và loại thao tác (% giảm giá, số tiền hoàn, số tiền void, override); tính cộng dồn theo booking và theo ca, gồm cả thao tác đã được duyệt	M	1	BR-064
FR-RBAC-005	Luồng Approval: tạo yêu cầu với giá trị khoá, chọn hoặc tự gửi người duyệt hợp lệ, duyệt/từ chối có lý do, hết hạn sau thời gian cấu hình (mặc định 30 phút), đối chiếu version trước khi thực thi	M	1	BR-064, BR-068 đề xuất

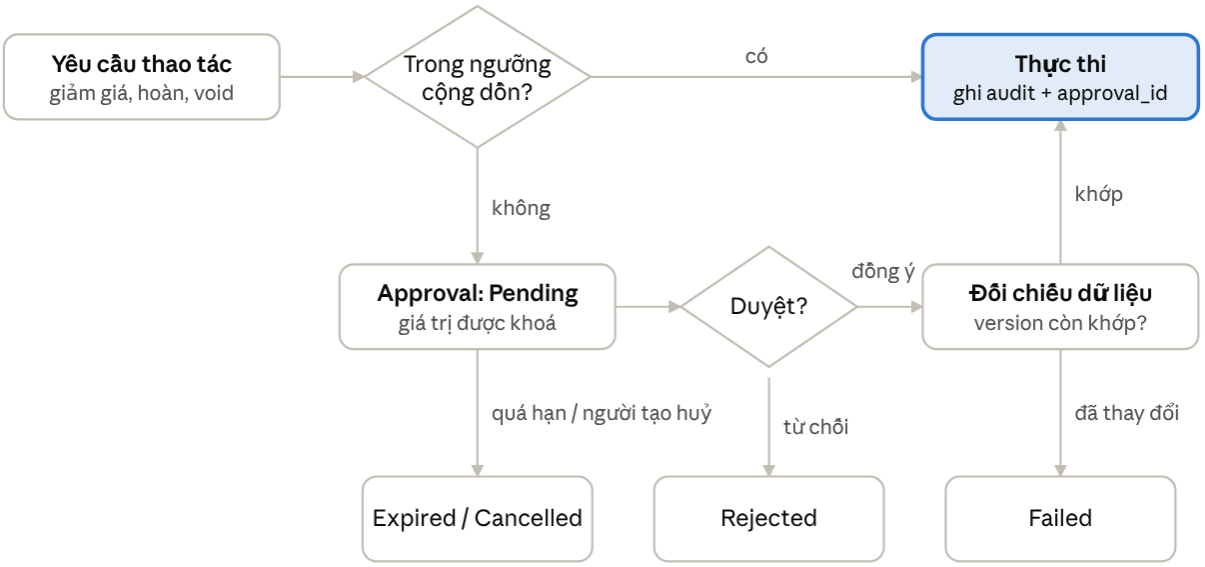
ID	Yêu cầu	Ưu tiên	Phase	BR / NFR
FR-RBAC-006	Tự duyệt chỉ cho R-OWN khi cấu hình cho phép (theo cơ sở); bắt buộc lý do; đánh dấu self_approved và vào báo cáo ngoại lệ	M	1	BR-064, ASM-040
FR-RBAC-007	Duyệt từ xa trên điện thoại: thông báo tới người duyệt hợp lệ, xác thực 2FA khi duyệt	M	1	NFR-SEC-001
FR-RBAC-008	Duyệt tại quầy: người duyệt nhập PIN cá nhân trên máy của người tạo; phiên của người tạo không đổi	S	1	BR-065
FR-RBAC-009	Gán vai trò có quyền tiền (R-FD, R-NA, R-ACC, R-MGR) hoặc đổi ngưỡng cần R-OWN duyệt; không ai tự gán vai trò cho chính mình	M	1	SEC-10
FR-RBAC-010	Màn hình quyền hiệu lực: vì sao người dùng có một quyền (từ vai trò nào, cơ sở nào)	S	1	–
FR-RBAC-011	Thay đổi quyền có hiệu lực ngay với mọi phiên đang mở (không chờ đăng nhập lại)	M	1	SEC-12
FR-RBAC-012	Luôn còn ít nhất một người dùng Active có vai trò R-OWN	M	1	–

4.3 Business rules áp dụng

BR-060, BR-061, BR-064, BR-065 (Phần 1) và **BR-068 đề xuất**: yêu cầu duyệt khoá giá trị và version của đối tượng tại lúc tạo; nếu đối tượng đã đổi khi duyệt xong thì không thực thi (Failed) và phải tạo yêu cầu mới; yêu cầu hết hạn tự chuyển Expired. **BR-069 đề xuất**: đối tượng thuộc cơ sở người dùng không được gán được trả về như không tồn tại, để không lộ việc nó có thật.

4.4 Luồng chính – UC-RBAC-001 Thao tác vượt ngưỡng

Thao tác vượt ngưỡng chỉ thực thi khi người khác duyệt và dữ liệu chưa đổi



Người duyệt phải khác người tạo, có quyền ở cơ sở đó và xác thực 2FA khi duyệt từ xa.
Owner tự duyệt chỉ khi cấu hình cho phép, bắt buộc lý do và luôn vào báo cáo ngoại lệ.

luồng duyệt · 2 điểm quyết định, 4 kết thúc

1. Người dùng thực hiện thao tác nhạy cảm (ví dụ Lễ tân giảm 15% cho booking).
2. Hệ thống cộng dồn giá trị đã áp trong phạm vi (booking, ca) với giá trị mới và so với ngưỡng của vai trò.
3. Trong ngưỡng: thực thi ngay, ghi audit.
4. Vượt ngưỡng: tạo Approval (Pending) khoá giá trị, version đối tượng và lý do; gửi thông báo tới người duyệt hợp lệ.
5. Người duyệt (khác người tạo, có quyền ở cơ sở) xác thực và đồng ý.
6. Hệ thống đối chiếu version: khớp thì thực thi với approval_id; không khớp thì Failed và báo người tạo.

4.5 Luồng thay thế

- **A1 – Duyệt tại quầy**: Manager nhập PIN trên máy lễ tân ở bước 5.
- **A2 – Owner tự duyệt**: khi Owner là người tạo và cấu hình cho phép, Owner nhập lý do và xác thực lại; Approval mang cờ self_approved.
- **A3 – Gán vai trò (UC-RBAC-002)**: Admin hoặc Manager gán vai trò; nếu vai trò có quyền tiền thì tạo Approval cho Owner; vai trò chỉ có hiệu lực sau khi Owner duyệt.
- **A4 – Người tạo huỷ**: Pending → Cancelled.

4.6 Xử lý ngoại lệ

Mã	Tình huống	Thông điệp / hành vi
ERR-RBAC-001	Không có quyền, hoặc đối tượng thuộc cơ sở không được gán	Thiếu quyền: "Bạn không có quyền thực hiện thao tác này". Khác cơ sở: "Không tìm thấy" (BR-069). Ghi log từ chối
ERR-RBAC-002	Vượt ngưỡng	Không thực thi; mở form tạo yêu cầu duyệt, hiển thị số đã dùng / ngưỡng
ERR-RBAC-003	Người duyệt là người tạo (không phải Owner được phép tự duyệt)	"Không thể tự duyệt yêu cầu của mình"
ERR-RBAC-004	Yêu cầu đã hết hạn	Expired; người tạo phải tạo lại
ERR-RBAC-005	Đối tượng đã đổi kể từ lúc yêu cầu	Failed; hiển thị thay đổi đã xảy ra
ERR-RBAC-006	Xác thực 2FA / PIN thất bại khi duyệt	Không duyệt; tính vào số lần sai
ERR-RBAC-007	Gán vai trò có quyền tiền không qua Owner, hoặc tự gán cho mình	Chuyển thành Approval cho Owner / từ chối tự gán
ERR-RBAC-008	Gỡ vai trò Owner của người Owner cuối cùng	Từ chối (FR-RBAC-012)
ERR-RBAC-009	Không có người duyệt hợp lệ nào đang hoạt động	Thông báo; gửi tới Owner; không tự hạ ngưỡng

4.7 Dữ liệu và trạng thái

Entity: Role, Permission, RolePermission, UserPropertyRole, ThresholdRule, Approval (mục 8). Approval: **Pending** → Approved → **Executed**; Pending → **Rejected** / **Expired** / **Cancelled**; Approved → **Failed**. Executed, Rejected, Expired, Cancelled, Failed là trạng thái cuối. UserPropertyRole có trạng thái **Pending approval** khi vai trò có quyền tiền chờ Owner duyệt.

4.8 Phụ thuộc

EMP (người dùng, 2FA, PIN), PROP, NTF (thông báo duyệt), AUD. Được gọi bởi mọi module; RATE, PAY, INV, BOOK, FO-NA dùng Approval ở đợt 2–3.

4.9 User story và tiêu chí nghiệm thu

US-RBAC-001 – Là Owner, tôi muốn mọi khoản hoàn tiền phải do người khác duyệt, để một nhân viên không thể tự rút tiền.

- **AC-RBAC-001-01** Given Lễ tân A tạo yêu cầu hoàn 500.000 đ; When A tự mở yêu cầu để duyệt; Then hệ thống từ chối ERR-RBAC-003.
- **AC-RBAC-001-02** Given Manager B duyệt sau 10 phút và booking không đổi; When B đồng ý với 2FA đúng; Then khoản hoàn được thực thi, audit ghi requester A, approver B, approval_id.
- **AC-RBAC-001-03** Given trong lúc chờ, booking có thêm một khoản hoàn khác; When B đồng ý; Then Approval chuyển Failed (ERR-RBAC-005), không có tiền nào được hoàn.

US-RBAC-002 – Là Owner, tôi muốn ngưỡng giảm giá tính cộng dồn, để không ai chia nhỏ để lọt ngưỡng.

- **AC-RBAC-002-01** Given ngưỡng Lễ tân 10%/booking và booking đã được giảm 6%; When Lễ tân giảm thêm 5%; Then không thực thi, yêu cầu duyệt với thông tin "đã dùng 6%, yêu cầu 5%, ngưỡng 10%".

US-RBAC-003 – Là Owner, tôi muốn nhân viên cơ sở A không xem được dữ liệu cơ sở B bằng bất kỳ cách nào.

- **AC-RBAC-003-01** Given Lễ tân chỉ được gán cơ sở A và booking X thuộc B; When gọi API đọc X bằng ID; Then nhận "không tìm thấy", giống hệt khi ID không tồn tại; sự kiện được ghi log.
- **AC-RBAC-003-02** Given cùng người dùng; When xuất báo cáo doanh thu không chọn cơ sở; Then file chỉ có dữ liệu cơ sở A.

US-RBAC-004 – Là Owner, tôi muốn Admin không thể tự cấp quyền tiền cho mình hoặc người khác mà tôi không biết.

- **AC-RBAC-004-01** Given Admin gán vai trò Kế toán cho nhân viên C; When lưu; Then vai trò ở trạng thái chờ, Owner nhận thông báo, C chưa có quyền Kế toán cho đến khi Owner duyệt.
- **AC-RBAC-004-02** Given Admin; When gán bất kỳ vai trò nào cho chính mình; Then từ chối ERR-RBAC-007.

US-RBAC-005 – Là Manager, tôi muốn duyệt ngay trên máy lễ tân khi đang đứng tại quầy.

- **AC-RBAC-005-01** Given yêu cầu Pending trên máy lễ tân; When Manager nhập PIN đúng của mình; Then Approval ghi approver là Manager, phiên máy vẫn của Lễ tân.

4.10 Test case

TC	Kiểm tra	AC	Loại
TC-RBAC-001	Tự duyệt bị chặn với mọi vai trò trừ Owner được phép	AC-RBAC-001-01	Bảo mật
TC-RBAC-002	Duyệt thành công ghi đủ requester, approver, approval_id	AC-RBAC-001-02	Chức năng
TC-RBAC-003	Đối tượng đổi trong lúc chờ → Failed	AC-RBAC-001-03	Đồng thời
TC-RBAC-004	Ngưỡng cộng dồn theo booking và theo ca	AC-RBAC-002-01	Biên
TC-RBAC-005	IDOR: đọc/sửa/xoá đối tượng cơ sở khác qua mọi endpoint (tự động)	AC-RBAC-003-01	Bảo mật
TC-RBAC-006	Báo cáo và file xuất chỉ chứa cơ sở được gán	AC-RBAC-003-02	Bảo mật
TC-RBAC-007	Admin gán vai trò tiền / tự gán	AC-RBAC-004-01, -02	Bảo mật
TC-RBAC-008	Duyệt tại quầy bằng PIN, sai PIN 5 lần	AC-RBAC-005-01	Chức năng
TC-RBAC-009	Yêu cầu hết hạn sau 30 phút	– (ERR-RBAC-004)	Biên
TC-RBAC-010	Thu hồi vai trò có hiệu lực với phiên đang mở	– (FR-RBAC-011)	Bảo mật

4.11 Self-review

- **Phát hiện**: Phần 1 chưa quy định chốt giá trị và hết hạn của yêu cầu duyệt → BR-068; cách trả lỗi khi truy cập chéo cơ sở → BR-069.
- **Thiếu người duyệt** khi homestay chỉ có 1 người trực đêm: phụ thuộc OQ-040; ERR-RBAC-009 không tự hạ ngưỡng để tránh lỗ hổng.
- **Thời hạn 30 phút** và PIN 6 số là giả định → OQ-042, OQ-044.
- **Quyền chi tiết của module tiền** mới ở mức sơ bộ trong ma trận mục 7; chốt ở đợt 2–3.

5. Module EMP – Tài khoản nhân viên và xác thực

Mỗi người dùng có đúng một tài khoản cá nhân, kể cả khi dùng chung máy quầy; nghỉ việc thì mất quyền ngay lập tức. Đây là điều kiện để mọi kiểm soát trong RBAC và AUD có ý nghĩa (SEC-11, SEC-12).

5.1 Mục tiêu và actor

- **Mục tiêu**: quản lý vòng đời tài khoản, đăng nhập, 2FA, PIN máy quầy. MVP chỉ ở mức tối giản (Phần 1 mục 10.1): không có hồ sơ nhân sự, phân ca chi tiết.
- **Actor**: R-OWN, R-ADM (toàn chuỗi), R-MGR (cơ sở mình) tạo, mời, ngưng; mọi người dùng tự quản lý mật khẩu, 2FA, PIN của mình.
- **Máy quầy**: máy được đăng ký là thiết bị dùng chung của một cơ sở. Trên máy này, người dùng đăng nhập đầy đủ một lần mỗi ca rồi chuyển qua lại bằng PIN.

5.2 Yêu cầu chức năng

ID	Yêu cầu	Ưu tiên	Phase	BR / NFR
FR-EMP-001	Tạo nhân viên: họ tên, SĐT, email (duy nhất toàn hệ thống), cơ sở, vai trò; gửi lời mời kích hoạt dùng một lần, hết hạn sau 24 giờ	M	1	BR-065
FR-EMP-002	Kích hoạt: đặt mật khẩu theo NFR-SEC-101; bắt buộc thiết lập 2FA nếu vai trò yêu cầu; đặt PIN 6 số nếu làm việc trên máy quầy	M	1	NFR-SEC-001
FR-EMP-003	Đăng nhập: khoá tạm 15 phút sau 5 lần sai; thông báo khi đăng nhập từ thiết bị mới với vai trò có quyền duyệt	M	1	SEC-13
FR-EMP-004	Máy quầy: đăng ký thiết bị; đổi người dùng bằng PIN; tự khoá sau 15 phút không thao tác; thao tác tiền yêu cầu nhập lại PIN; mỗi thao tác ghi đúng người đang dùng	M	1	BR-065, SEC-11
FR-EMP-005	Ngưng nhân viên: khoá tài khoản, thu hồi mọi phiên và token trong vòng 1 phút, huỷ các Approval Pending của người đó; giữ nguyên dữ liệu lịch sử	M	1	BR-065, SEC-12
FR-EMP-006	Đặt lại mật khẩu tự phục vụ qua email; đặt lại 2FA của người khác chỉ R-OWN hoặc R-ADM, sau khi xác minh trực tiếp, có audit	M	1	SEC-13

ID	Yêu cầu	Ưu tiên	Phase	BR / NFR
FR-EMP-007	Danh sách phiên đang hoạt động của mỗi người dùng; đăng xuất từ xa	S	1	–
FR-EMP-008	Dữ liệu nhân viên thu tối thiểu (họ tên, SĐT, email); ẩn danh theo chính sách lưu trữ khi nghỉ việc quá thời hạn	S	1	[Q] OQ-019
FR-EMP-009	Một người có thể làm ở nhiều cơ sở với vai trò khác nhau bằng cùng một tài khoản; giao diện chọn cơ sở đang làm việc	M	1	OQ-041

5.3 Business rules áp dụng

BR-061, BR-065 (Phần 1). Không có BR mới; các ngưỡng số (5 lần, 15 phút, 24 giờ, PIN 6 số) nằm trong NFR mục 9.

5.4 Luồng chính – UC-EMP-001 Mời và kích hoạt nhân viên

1. R-MGR tạo nhân viên, chọn cơ sở và vai trò. Vai trò có quyền tiền chuyển sang chờ Owner duyệt (FR-RBAC-009).
2. Hệ thống gửi lời mời qua email (hoặc SĐT); tài khoản ở trạng thái Invited.
3. Nhân viên mở liên kết, đặt mật khẩu, thiết lập 2FA (nếu bắt buộc) và PIN.
4. Tài khoản chuyển Active; ghi audit.

5.5 Luồng thay thế

- **A1 – UC-EMP-002 Đổi người trên máy quầy**: Lễ tân B chạm "Đổi người", chọn tên, nhập PIN; phiên của A được khoá (không đăng xuất), mọi thao tác tiếp theo ghi tên B.
- **A2 – UC-EMP-003 Ngưng nhân viên**: R-MGR chọn Ngưng, nhập lý do; hệ thống khoá tài khoản, thu hồi phiên, huỷ Approval Pending, thông báo Owner.
- **A3 – Lời mời hết hạn**: R-MGR gửi lại; liên kết cũ mất hiệu lực.
- **A4 – Kích hoạt lại nhân viên đã ngưng**: cần Owner duyệt; vai trò cũ không tự khôi phục, phải gán lại.

5.6 Xử lý ngoại lệ

Mã	Tình huống	Thông điệp / hành vi
ERR-EMP-001	Email hoặc SĐT đã thuộc tài khoản khác	Đề nghị gán thêm cơ sở cho tài khoản có sẵn thay vì tạo mới
ERR-EMP-002	Liên kết mời hết hạn hoặc đã dùng	"Liên kết không còn hiệu lực, liên hệ quản lý"
ERR-EMP-003	Sai mật khẩu 5 lần	Khoá 15 phút; thông điệp không tiết lộ tài khoản có tồn tại hay không
ERR-EMP-004	PIN yếu (lặp, dãy số, ngày sinh) hoặc sai PIN 5 lần	Từ chối PIN yếu; sai 5 lần thì yêu cầu đăng nhập đầy đủ
ERR-EMP-005	Ngưng Owner cuối cùng	Từ chối (FR-RBAC-012)
ERR-EMP-006	Admin tự đặt lại 2FA của chính mình qua chức năng quản trị	Từ chối; phải do Owner thực hiện
ERR-EMP-007	Đổi người băng PIN trên thiết bị chưa đăng ký là máy quầy	Không cho; yêu cầu đăng nhập đầy đủ

5.7 Dữ liệu và trạng thái

Entity: User, Device, Session (mục 8).

Chuyển trạng thái	Điều kiện	Actor
(mới) → Invited	Email/SĐT hợp lệ, chưa dùng	R-OWN, R-ADM, R-MGR
Invited → Active	Hoàn tất kích hoạt	Nhân viên
Invited → Expired	Quá 24 giờ	Hệ thống
Active → Locked	Sai mật khẩu 5 lần	Hệ thống
Locked → Active	Hết 15 phút hoặc đặt lại mật khẩu	Hệ thống, nhân viên
Active / Locked → Suspended	Ngưng nhân viên	R-OWN, R-ADM, R-MGR
Suspended → Active	Owner duyệt; vai trò gán lại	R-OWN

5.8 Phụ thuộc

RBAC (vai trò), PROP (cơ sở), NTF (gửi lời mời, cảnh báo đăng nhập), AUD. Cung cấp danh tính người thao tác cho mọi module.

5.9 User story và tiêu chí nghiệm thu

US-EMP-001 – Là Owner, tôi muốn biết chính xác ai đã thao tác trên máy quầy dùng chung.

- **AC-EMP-001-01** Given A đang dùng máy quầy; When B đổi người bằng PIN đúng và tạo booking; Then booking và audit ghi người tạo là B, thiết bị là máy quầy đó.
- **AC-EMP-001-02** Given máy quầy không có thao tác 15 phút; When ai đó chạm màn hình; Then màn hình khoá, yêu cầu PIN.
- **AC-EMP-001-03** Given B đã đăng nhập bằng PIN; When B ghi nhận thanh toán; Then hệ thống yêu cầu nhập lại PIN trước khi lưu.

US-EMP-002 – Là Manager, tôi muốn nhân viên nghỉ việc mất quyền ngay, kể cả trên điện thoại cá nhân.

- **AC-EMP-002-01** Given nhân viên C đang đăng nhập trên điện thoại; When Manager ngưng C; Then trong vòng 1 phút mọi yêu cầu từ phiên của C bị từ chối và C bị đưa về màn hình đăng nhập.
- **AC-EMP-002-02** Given C có 1 Approval Pending; When C bị ngưng; Then Approval chuyển Cancelled.

US-EMP-003 – Là nhân viên, tôi muốn làm việc ở hai cơ sở với một tài khoản.

- **AC-EMP-003-01** Given D là Lễ tân ở A và Buồng phòng ở B; When D chọn cơ sở B; Then D chỉ thấy chức năng buồng phòng của B, không thấy dữ liệu khách của B.

5.10 Test case

TC	Kiểm tra	AC	Loại
TC-EMP-001	Ghi đúng người thao tác sau khi đổi bằng PIN	AC-EMP-001-01	Chức năng
TC-EMP-002	Tự khoá sau 15 phút	AC-EMP-001-02	Biên
TC-EMP-003	Nhập lại PIN trước thao tác tiền	AC-EMP-001-03	Bảo mật
TC-EMP-004	Thu hồi phiên trong 1 phút sau khi ngưng	AC-EMP-002-01	Bảo mật

TC	Kiểm tra	AC	Loại
TC-EMP-005	Huỷ Approval Pending khi ngưng	AC-EMP-002-02	Chức năng
TC-EMP-006	Quyền theo cơ sở đang chọn	AC-EMP-003-01	Bảo mật
TC-EMP-007	Khoá sau 5 lần sai; thông điệp giống nhau cho tài khoản có và không tồn tại	– (ERR-EMP-003)	Bảo mật
TC-EMP-008	Từ chối PIN yếu	– (ERR-EMP-004)	Biên

5.11 Self-review

- **Phương thức 2FA** chưa chốt: ứng dụng xác thực an toàn hơn nhưng khó với nhân viên lớn tuổi; OTP qua SMS/Zalo tốn phí và kém an toàn hơn → OQ-043.
- **Đăng ký máy quầy** thêm bước cài đặt khi go-live → OQ-044; cần vào checklist 10.3 của Phần 1.
- **Nhân viên buồng phòng dùng điện thoại cá nhân**: không phải máy quầy, nên đăng nhập bình thường; giao diện HK không hiển thị dữ liệu khách (BR-066) để giảm rủi ro mất máy.
- **Không phát hiện mâu thuẫn** với RBAC.

6. Module AUD (khung) – Nhật ký thao tác

Audit log được ghi trong cùng giao dịch với thao tác, chỉ ghi thêm và có chuỗi hash; nếu không ghi được log thì thao tác thất bại. Đợt 1 dựng khung và danh mục sự kiện của module nền tảng; sự kiện tiền và booking được bổ sung ở đợt 2–3.

6.1 Mục tiêu và actor

- **Mục tiêu**: truy vết được ai làm gì, ở đâu, khi nào, trên thiết bị nào, được ai duyệt; đủ tin cậy để làm bằng chứng khi có gian lận. Phục vụ BG-07.
- **Actor**: hệ thống ghi; R-OWN xem tất cả; R-MGR xem log nghiệp vụ của cơ sở mình; R-ADM xem log bảo mật và quyền. Không vai trò nào sửa hoặc xoá được.

6.2 Yêu cầu chức năng

ID	Yêu cầu	Ưu tiên	Phase	BR / NFR
FR-AUD-001	Ghi mọi sự kiện trong danh mục 6.7	M	1	BR-061
FR-AUD-002	Bản ghi gồm: actor, vai trò hiệu lực, cơ sở, thiết bị, IP, thời điểm (UTC và giờ cơ sở), business date, hành động, đối tượng, giá trị trước/sau (trường cá nhân đã che), approval_id, reason_code, kết quả	M	1	BR-061
FR-AUD-003	Chỉ ghi thêm; mỗi bản ghi có prev_hash; job kiểm tra chuỗi hằng ngày, cảnh báo Owner khi đứt	M	1	NFR-AUD-001
FR-AUD-004	Ghi cả thao tác đọc dữ liệu nhạy cảm: xem đầy đủ giấy tờ, xuất danh sách khách, xuất báo cáo có dữ liệu cá nhân	M	1	BR-063, BR-066
FR-AUD-005	Ghi cả thao tác bị từ chối do thiếu quyền, hoặc truy cập chéo cơ sở	M	1	BR-069 đề xuất
FR-AUD-006	Log ghi trong cùng giao dịch CSDL với thao tác; ghi log lỗi thì thao tác bị huỷ	M	1	–
FR-AUD-007	Tra cứu theo đối tượng, người dùng, loại sự kiện, khoảng thời gian; xuất kết quả tra cứu (việc xuất cũng được log)	M	1	–
FR-AUD-008	Tab lịch sử trên mỗi đối tượng (cơ sở, phòng, người dùng, cấu hình)	S	1	–
FR-AUD-009	Thời gian lưu và ẩn danh theo chính sách dữ liệu cá nhân	S	1	[Q] OQ-019, BR-062

6.3 Business rules áp dụng

BR-061, BR-062, BR-063, BR-066 (Phần 1) và BR-069 (đề xuất ở RBAC).

6.4 Luồng chính – UC-AUD-001 Ghi log một thao tác

1. Module nghiệp vụ mở giao dịch, thực hiện thay đổi.
2. Trong cùng giao dịch, AUD tạo bản ghi: đọc prev_hash của bản ghi cuối (theo chuỗi của cơ sở), tính hash của bản ghi mới, che trường cá nhân.

3. Commit cả hai; lỗi bất kỳ bước nào thì rollback cả hai.

6.5 Luồng thay thế

- **A1 – UC-AUD-002 Kiểm tra toàn vẹn**: job hằng ngày tính lại chuỗi; đứt chuỗi thì ghi sự kiện bảo mật và gửi cảnh báo khẩn tới Owner.
- **A2 – UC-AUD-003 Tra cứu**: Manager xem lịch sử một phòng; chỉ thấy sự kiện thuộc cơ sở mình.

6.6 Xử lý ngoại lệ

Mã	Tình huống	Thông điệp / hành vi
ERR-AUD-001	Ghi log thất bại	Thao tác nghiệp vụ bị huỷ; "Không thể lưu, vui lòng thử lại"; cảnh báo kỹ thuật
ERR-AUD-002	Phát hiện đứt chuỗi hash	Cảnh báo khẩn tới Owner, ghi vị trí đứt; không tự sửa
ERR-AUD-003	Có lệnh sửa/xoá bản ghi log	CSDL từ chối (quyền CSDL chỉ cho INSERT); ghi sự kiện bảo mật

6.7 Danh mục sự kiện đợt 1

Nhóm	Sự kiện	Mức
Xác thực	Đăng nhập thành công/thất bại, khoá tài khoản, đổi người bằng PIN, đăng nhập thiết bị mới, đăng xuất từ xa	Bảo mật
Tài khoản	Mời, kích hoạt, ngưng, kích hoạt lại, đổi mật khẩu, đặt lại 2FA/PIN	Bảo mật
Quyền	Gán/gỡ vai trò, đổi ngưỡng, bật/tắt tự duyệt, truy cập bị từ chối	Bảo mật
Duyệt	Tạo, duyệt, từ chối, hết hạn, huỷ, thất bại Approval; tự duyệt	Nghiệp vụ
Cấu hình	Mọi thay đổi tham số, TaxRule, mã lý do, dịch vụ, mẫu, đánh số	Nghiệp vụ
Cơ sở	Tạo, sửa thông tin pháp lý, chuyển trạng thái	Nghiệp vụ
Phòng	Tạo, sửa, ngưng bán, đổi loại, đổi cha–con, nhập hàng loạt	Nghiệp vụ

Nhóm	Sự kiện	Mức
Dữ liệu cá nhân	Xem đầy đủ giấy tờ, xuất danh sách, xuất log	Bảo mật
Toàn vẹn	Đứt chuỗi hash, lệnh sửa/xoá log bị từ chối	Bảo mật

6.8 Dữ liệu và phụ thuộc

Entity: AuditLog (mục 8). Chuỗi hash tách theo cơ sở và một chuỗi riêng cho sự kiện cấp chuỗi, để ghi đồng thời giữa các cơ sở không tranh chấp. Được gọi bởi mọi module; phụ thuộc EMP (danh tính), RBAC (quyền xem), NTF (cảnh báo).

6.9 User story và tiêu chí nghiệm thu

US-AUD-001 – Là Owner, tôi muốn nhật ký không thể bị sửa lén, kể cả bởi Admin.

- **AC-AUD-001-01** Given bản ghi log #1000 tồn tại; When một tài khoản CSDL của ứng dụng gửi lệnh UPDATE hoặc DELETE lên bảng log; Then CSDL từ chối và sự kiện bảo mật được ghi.
- **AC-AUD-001-02** Given ai đó sửa trực tiếp một bản ghi bằng quyền quản trị CSDL; When job kiểm tra chạy; Then Owner nhận cảnh báo chỉ ra vị trí đứt chuỗi.

US-AUD-002 – Là Manager, tôi muốn biết ai đã đổi giờ check-in của cơ sở.

- **AC-AUD-002-01** Given giờ check-in đổi từ 14:00 sang 13:00; When Manager mở lịch sử cấu hình; Then thấy người sửa, thời điểm, giá trị trước 14:00 và sau 13:00.

US-AUD-003 – Là Owner, tôi muốn biết ai đã xem giấy tờ của khách.

- **AC-AUD-003-01** Given Lễ tân mở xem đầy đủ CCCD của khách X; When Owner tra cứu log theo khách X; Then thấy sự kiện xem với người, thời điểm, thiết bị; bản ghi không chứa số CCCD rõ.

6.10 Test case

TC	Kiểm tra	AC	Loại
TC-AUD-001	UPDATE/DELETE bảng log bằng tài khoản ứng dụng	AC-AUD-001-01	Bảo mật
TC-AUD-002	Sửa bản ghi bằng quyền quản trị, job phát hiện đứt chuỗi	AC-AUD-001-02	Bảo mật
TC-AUD-003	Giá trị trước/sau của thay đổi cấu hình	AC-AUD-002-01	Chức năng

TC	Kiểm tra	AC	Loại
TC-AUD-004	Log xem giấy tờ không chứa dữ liệu rõ	AC-AUD-003-01	Bảo mật
TC-AUD-005	Lỗi ghi log làm rollback thao tác	– (ERR-AUD-001)	Chức năng
TC-AUD-006	2 cơ sở ghi log đồng thời, chuỗi mỗi cơ sở còn liền	– (6.8)	Đồng thời

6.11 Self-review

- **Chuỗi hash đơn** cho toàn hệ thống sẽ thành nút thắt khi ghi đồng thời → đã tách theo cơ sở (6.8).
- **Người có quyền quản trị CSDL** vẫn sửa được log; chuỗi hash chỉ phát hiện, không ngăn. Nếu cần mạnh hơn, đẩy bản sao log ra kho lưu trữ không sửa được (Phase 2) – ghi nhận để Dev Lead đánh giá chi phí.
- **Danh mục sự kiện tiền và booking** chưa có; phải bổ sung ở đợt 2–3 trước khi baseline FR của các module đó.

7. Role & Permission Matrix v0.1

Ma trận chốt quyền của 6 module đợt 1; quyền của module tiền và booking ở bảng 7.2 chỉ là sơ bộ để Dev thiết kế khung, sẽ chốt ở đợt 2–3. Mọi vai trò trừ R-OWN và R-ADM chỉ có hiệu lực trong cơ sở được gán.

Ký hiệu: ✓ được làm · A được tạo yêu cầu, cần người khác duyệt (hoặc duyệt khi vượt ngưỡng) · Đ chỉ đọc · – không có quyền · ✓* được làm, nhưng Owner phải duyệt mới có hiệu lực.

7.1 Quyền đợt 1

Quyền	OWN	MGR	FD	NA	ACC	HKS	HK	MNT	ADM
CFG – xem tham số vận hành	✓	✓	Đ	Đ	Đ	Đ	–	–	✓
CFG – sửa giờ, hạn giữ/cọc, trạng thái buồng tối thiểu	✓	✓	–	–	–	–	–	–	–
CFG – sửa thuế, chế độ giá, làm tròn	✓	–	–	–	Đ	–	–	–	–
CFG – mẫu in, mẫu tin, đánh số	✓	✓	–	–	–	–	–	–	✓

Quyền	OWN	MGR	FD	NA	ACC	HKS	HK	MNT	ADM
CFG – mã lý do, danh mục dịch vụ	✓	✓	Đ	Đ	✓	Đ	–	–	✓
PROP – tạo, kích hoạt, tạm ngưng, đóng cơ sở	✓	–	–	–	–	–	–	–	–
PROP – sửa thông tin vận hành	✓	✓	Đ	Đ	Đ	Đ	–	–	Đ
PROP – sửa thông tin pháp lý, mã số thuế	✓	–	–	–	Đ	–	–	–	–
ROOM – xem loại phòng, phòng	✓	✓	✓	✓	✓	✓	Đ	Đ	✓
ROOM – tạo, sửa, ngưng bán, cấu trúc cha–con	✓	✓	–	–	–	–	–	–	–
ROOM – nhập hàng loạt	✓	✓	–	–	–	–	–	–	✓
RBAC – gán vai trò không có quyền tiền (HKS, HK, MNT)	✓	✓	–	–	–	–	–	–	✓
RBAC – gán vai trò có quyền tiền (FD, NA, ACC, MGR)	✓	✓*	–	–	–	–	–	–	✓*
RBAC – gán vai trò OWN, ADM	✓	–	–	–	–	–	–	–	–
RBAC – đổi ngưỡng, bật/tắt tự duyệt	✓	–	–	–	–	–	–	–	–
RBAC – duyệt yêu cầu của người khác	✓	✓	–	–	✓ (tiền)	–	–	–	–
RBAC – tự duyệt	✓ (nếu bật)	–	–	–	–	–	–	–	–
EMP – mời, ngưng nhân viên	✓	✓	–	–	–	–	–	–	✓
EMP – kích hoạt lại nhân viên đã ngưng	✓	A	–	–	–	–	–	–	A
EMP – đặt lại 2FA/PIN của người khác	✓	–	–	–	–	–	–	–	✓ (trừ chính mình)
EMP – đăng ký máy quầy	✓	✓	–	–	–	–	–	–	✓
AUD – xem log nghiệp vụ	✓	✓	–	–	✓ (tiền)	–	–	–	–
AUD – xem log bảo mật, quyền	✓	–	–	–	–	–	–	–	✓
AUD – sửa, xoá log	–	–	–	–	–	–	–	–	–

7.2 Quyền sơ bộ cho đợt 2–3

Quyền	OWN	MGR	FD	NA	ACC	HKS	HK	MNT	ADM
Xem đầy đủ giấy tờ khách	✓	✓	✓	✓	–	–	–	–	–
Xuất danh sách khách / file khai báo lưu trú	✓	✓	–	–	–	–	–	–	–
Giảm giá trong ngưỡng / vượt ngưỡng	✓	✓ / A	✓ / A	✓ / A	–	–	–	–	–
Ghi nhận thanh toán	✓	✓	✓	✓	✓	–	–	–	–
Xác nhận đối soát chuyển khoản	✓	✓	–	–	✓	–	–	–	–
Hoàn tiền, void	A	A	A	A	A	–	–	–	–
Hoàn tiền mặt cho khoản thu không phải tiền mặt	✓	–	–	–	–	–	–	–	–
Override overbooking / trạng thái buồng	✓	✓	–	–	–	–	–	–	–
Chạy Night Audit	✓	✓	–	✓	–	–	–	–	–
Mở lại business date đã đóng	✓	–	–	–	–	–	–	–	–
Tạo tài khoản công nợ	✓	–	–	–	✓	–	–	–	–
Cập nhật trạng thái buồng	✓	✓	✓	✓	–	✓	✓	–	–
Mở / đóng ticket bảo trì, khoá OOO	✓	✓ / ✓	✓ / –	✓ / –	–	✓ / –	✓ / –	✓ / A	–

Với hoàn tiền và void, "A" áp cho cả Owner: người tạo không bao giờ tự duyệt, trừ Owner khi cấu hình tự duyệt được bật (BR-064).

8. Data Dictionary – các entity đợt 1

Bảng dưới định nghĩa 21 entity của đợt 1 theo PostgreSQL (ASM-036). Tiền lưu bằng số nguyên VND (bigint), không dùng số thực; thời điểm lưu UTC (timestamptz); ngày nghiệp vụ lưu kiểu date theo giờ cơ sở.

Trường chung (mọi entity trừ AuditLog): id (uuid, khoá chính), created_at, created_by, updated_at, updated_by, version (integer, optimistic locking). Entity thuộc cơ sở có thêm property_id (uuid, bắt buộc, dùng cho row-level security).

Entity	Trường	Kiểu	BB	Ràng buộc / ghi chú
Property	code	varchar(20)	✓	Duy nhất trong chuỗi; chữ hoa, số, gạch ngang
	name, address	varchar	✓	name ≤ 120 ký tự
	timezone	varchar(40)	✓	IANA, ví dụ Asia/Ho_Chi_Minh; chỉ sửa khi Draft
	legal_form	enum	✓	household_business / enterprise [Q] OQ-037
	tax_code	varchar(14)	–	10 hoặc 13 số (có gạch)
	price_tax_mode	enum	✓	inclusive / exclusive
	status	enum	✓	draft / active / suspended / closed
BusinessDay	business_date	date	✓	UNIQUE(property_id, business_date)
	status	enum	✓	open / auditing / closed; tối đa 1 open mỗi cơ sở
	closed_at, closed_by, reopened_by	timestamptz, uuid	–	reopened_by chỉ Owner (BR-045)
SystemParameter	key	varchar(60)	✓	Từ danh mục cố định
	scope	enum + uuid	✓	chain hoặc property_id
	value	jsonb	✓	Kiểm tra theo schema của từng key
	effective_from, effective_to	date	✓ / –	Không chồng khoảng cùng (key, scope)
	status	enum	✓	scheduled / active / superseded / cancelled
TaxRule	charge_type	enum	✓	room / surcharge / service / fee

Entity	Trường	Kiểu	BB	Ràng buộc / ghi chú
	rate_bp	integer	✓	Thuế suất đơn vị 0,01% (800 = 8%); 0–10000
	effective_from, effective_to	date	✓ / –	Không chồng khoảng cùng charge_type, scope
ReasonCode	group, code	enum, varchar(30)	✓	UNIQUE(group, code)
	label_vi, label_en	varchar	✓ / –	
	active	boolean	✓	Mã đã dùng chỉ được đặt false
ServiceItem	name, unit	varchar	✓	
	unit_price	bigint	✓	⩾ 0, VND
	charge_type	enum	✓	Xác định TaxRule áp dụng
	active	boolean	✓	
NumberSequence	doc_type	enum	✓	booking / receipt / invoice
	prefix_pattern	varchar(30)	✓	Ví dụ PT-{YYYY}-; biến từ danh sách cố định
	next_value	bigint	✓	Cấp trong giao dịch, khoá dòng (FR-CFG-006)
Template	channel, language	enum	✓	print / email / message; vi / en
	body	text	✓	Chỉ chứa biến trong danh sách cho phép
RoomType	code, name	varchar	✓	UNIQUE(property_id, code)
	base_occupancy, max_occupancy	smallint	✓	1 ⩽ base ⩽ max ⩽ 30
	max_extra_beds	smallint	✓	⩾ 0

Entity	Trường	Kiểu	BB	Ràng buộc / ghi chú
	is_sellable	boolean	✓	
Room	room_no	varchar(10)	✓	UNIQUE(property_id, room_no)
	room_type_id	uuid	✓	Cùng cơ sở
	kind	enum	✓	room / unit / bed
	parent_id	uuid	–	Cùng cơ sở; tối đa 2 cấp; bed không làm cha [Q]
	building, floor	varchar	–	
	sell_from, sell_to	date	✓ / –	Khoảng đang bán; sell_to = ngày ngưng bán
	hk_status, occupancy_status	enum	✓	Do HK, FO cập nhật; ROOM chỉ khởi tạo
RoomTypeInventory	room_type_id, stay_date	uuid, date	✓	Khoá chính kép
	capacity	smallint	✓	Do ROOM cập nhật
	sold	smallint	✓	Do BOOK, MNT cập nhật; CHECK 0 ⩽ sold ⩽ capacity
User	full_name	varchar(120)	✓	
	email	citext	✓	Duy nhất toàn hệ thống
	phone	varchar(15)	–	E.164; duy nhất nếu có
	password_hash	varchar	✓	Argon2id (NFR-SEC-102)
	mfa_secret	bytea	–	Mã hoá bằng khoá KMS
	pin_hash	varchar	–	Argon2id; không lưu PIN rõ
	status	enum	✓	invited / active / locked / suspended / expired

Entity	Trường	Kiểu	BB	Ràng buộc / ghi chú
	failed_attempts, locked_until	smallint, timestamptz	✓ / –	
Device	property_id, name	uuid, varchar	✓	
	kind	enum	✓	shared_terminal / personal
	registered_by, revoked_at	uuid, timestamptz	✓ / –	
Session	user_id, device_id	uuid	✓ / –	
	token_hash	varchar	✓	Không lưu token rõ
	expires_at, revoked_at, last_seen_at	timestamptz	✓ / – / ✓	Thu hồi khi ngưng nhân viên hoặc đổi quyền
Role	code	enum	✓	9 mã ở mục 0.2; cố định trong MVP
	scope_level	enum	✓	chain / property
Permission	code	varchar(60)	✓	Ví dụ room.write, refund.request; duy nhất
RolePermission	role_id, permission_id	uuid	✓	Khoá chính kép
UserPropertyRole	user_id, role_id	uuid	✓	
	property_id	uuid	–	NULL khi vai trò cấp chuỗi
	status	enum	✓	pending_approval / active / revoked
	approval_id	uuid	–	Bắt buộc khi vai trò có quyền tiền
ThresholdRule	role_id, action	uuid, enum	✓	action: discount / refund / void / override
	limit_type, limit_value	enum, bigint	✓	percent_bp hoặc amount_vnd

Entity	Trường	Kiểu	BB	Ràng buộc / ghi chú
	window	enum	✓	per_booking / per_shift
Approval	type	enum	✓	discount / refund / void / override / role_grant / threshold_change / reopen_day / reactivate_user
	target_type, target_id, target_version	varchar, uuid, integer	✓	Dùng để đối chiếu version (BR-068)
	payload	jsonb	✓	Giá trị được khoá tại lúc tạo
	amount	bigint	–	VND nếu là thao tác tiền
	requester_id, approver_id	uuid	✓ / –	CHECK approver_id ≠ requester_id hoặc self_approved = true
	self_approved	boolean	✓	Chỉ true khi requester có vai trò Owner và cấu hình cho phép
	reason, decision_reason	text	✓ / –	
	status	enum	✓	pending / approved / executed / rejected / expired / cancelled / failed
	expires_at	timestamptz	✓	Mặc định created_at + 30 phút [A] OQ-042
AuditLog	seq	bigint	✓	Tăng dần theo chain_key; không có trường chung
	chain_key	varchar	✓	property_id hoặc "chain"
	at, business_date	timestamptz, date	✓ / –	

Entity	Trường	Kiểu	BB	Ràng buộc / ghi chú
	actor_id, effective_roles, device_id, ip	uuid, text[], uuid, inet	✓ / ✓ / – / ✓	
	action, target_type, target_id	varchar, varchar, uuid	✓	
	before, after	jsonb	–	Trường cá nhân đã che (BR-061)
	approval_id, reason_code, result	uuid, varchar, enum	– / – / ✓	result: success / denied
	prev_hash, hash	bytea	✓	SHA-256; quyền CSDL chỉ INSERT

9. NFR bảo mật chi tiết

14 yêu cầu dưới đây chi tiết hoá NFR khung của Phần 1 (mục 3.4) cho phạm vi đợt 1; mỗi yêu cầu có cách kiểm chứng để QA đưa vào test. Con số là đề xuất [A], chờ Owner và Dev Lead duyệt.

ID	Nhóm	Yêu cầu	Kiểm chứng	Nguồn
NFR-SEC-101	Mật khẩu	Tối thiểu 10 ký tự; từ chối mật khẩu nằm trong danh sách đã bị lộ và mật khẩu chứa email/SĐT; không bắt đổi định kỳ, chỉ đổi khi có nghi ngờ lộ	TC đặt mật khẩu yếu, mật khẩu trong danh sách lộ	NFR-SEC-001
NFR-SEC-102	Lưu trữ bí mật	Mật khẩu và PIN băm bằng Argon2id; token phiên chỉ lưu hash; khóa bí mật 2FA mã hoá bằng khoá KMS	Review cấu hình; kiểm tra CSDL không có giá trị rõ	NFR-SEC-003

ID	Nhóm	Yêu cầu	Kiểm chứng	Nguồn
NFR-SEC-103	2FA	Bắt buộc cho R-OWN, R-MGR, R-ACC, R-ADM; TOTP qua ứng dụng xác thực kèm 10 mã dự phòng dùng một lần; phương thức chờ OQ-043	TC đăng nhập thiếu 2FA bị chặn	NFR-SEC-001
NFR-SEC-104	Phiên	Phiên cá nhân hết hạn sau 8 giờ hoặc 30 phút không hoạt động; máy quầy tự khoá sau 15 phút; cookie HttpOnly, Secure, SameSite=Lax; thu hồi phiên có hiệu lực ⩽ 1 phút	TC-EMP-002, TC-EMP-004	BR-065
NFR-SEC-105	Chống dò mật khẩu	Khoá tài khoản 15 phút sau 5 lần sai; giới hạn 20 lần đăng nhập/phút mỗi IP; thông điệp lỗi không tiết lộ tài khoản có tồn tại	TC-EMP-007	SEC-13
NFR-SEC-106	Phân quyền	Kiểm tra quyền phía server cho 100% endpoint; mặc định từ chối (endpoint mới không khai báo quyền thì không ai gọi được)	Test tự động quét mọi endpoint với mỗi vai trò	NFR-SEC-002
NFR-SEC-107	Cách ly cơ sở	Row-level security trên mọi bảng có property_id; kết nối CSDL của ứng dụng không có quyền bỏ qua RLS	TC-RBAC-005, TC-RBAC-006	BR-060
NFR-SEC-108	Chống tấn công web	Bảo vệ CSRF cho mọi thao tác ghi; escape theo ngữ cảnh; Content-Security-Policy chặn script nội tuyến; truy vấn tham số hoá	Quét bảo mật tự động mỗi bản phát hành	NFR-SEC-005
NFR-SEC-109	Truyền tải	TLS 1.2 trở lên cho mọi kết nối, kể cả nội bộ giữa dịch vụ; HSTS	Kiểm tra cấu hình TLS	NFR-SEC-003

ID	Nhóm	Yêu cầu	Kiểm chứng	Nguồn
NFR-SEC-110	Bí mật hệ thống	Khoá API, mật khẩu CSDL, khoá HMAC nằm trong kho bí mật; không có trong mã nguồn hoặc log; xoay khoá được không cần dừng hệ thống	Quét mã nguồn tìm bí mật	NFR-SEC-003
NFR-SEC-111	Nhật ký	Log ứng dụng (kỹ thuật) không chứa mật khẩu, token, số giấy tờ, số thẻ; audit log theo FR-AUD-002, FR-AUD-003	Quét log mẫu tìm dữ liệu nhạy cảm	NFR-AUD-001
NFR-SEC-112	Thư viện bên thứ ba	Quét lỗ hổng phụ thuộc mỗi bản phát hành; lỗ hổng mức Critical vá trong 7 ngày	Báo cáo quét trong pipeline	–
NFR-SEC-113	Kiểm thử xâm nhập	Pentest độc lập trước go-live, tập trung IDOR, leo thang quyền, phiên máy quầy, luồng duyệt	Báo cáo pentest, 0 lỗi High mở	Phần 1 mục 10.2
NFR-SEC-114	Sao lưu	Backup mã hoá, lưu tách biệt với môi trường chạy; thử khôi phục mỗi quý; RPO ⩽ 15 phút, RTO ⩽ 4 giờ	Biên bản thử khôi phục	NFR-AVL-001

10. Self-review đợt 1, BR và OQ mới, truy vết

Đợt 1 có 59 FR, 20 user story, 37 tiêu chí nghiệm thu và 44 test case. Self-review phát sinh 4 BR và 6 OQ mới cần đưa ngược vào Phần 1; không phát hiện mâu thuẫn với BR hiện có.

10.1 Checklist self-review

Câu hỏi	CFG	PROP	ROOM	RBAC	EMP	AUD
Thiếu business flow?	Không	Không	Không	Không	Không	Không
Thiếu exception flow?	Không	Không	Đã thêm ERR-ROOM-008	Đã thêm ERR-RBAC-009	Không	Không
Thiếu validation?	Không	Không	Không	Không	Không	Không

Câu hỏi	CFG	PROP	ROOM	RBAC	EMP	AUD
Thiếu phân quyền?	Không	Không	Không	Không	Không	Không
Thiếu trạng thái?	Không	Không	Không	Không	Không	Không (log không có trạng thái)
Thiếu business rule?	BR-009	Không	BR-019	BR-068, BR-069	Không	Không
Mâu thuẫn với module khác?	Không	Không	Không	Không	Không	Không
Còn chỗ chưa đủ rõ cho Dev?	Đánh số hoá đơn (OQ-015, OQ-046)	Trường pháp lý (OQ-037)	Cha–con (OQ-001)	Thời hạn duyệt (OQ-042)	Phương thức 2FA (OQ-043)	Lưu trữ (OQ-019)

10.2 Business rule đề xuất thêm vào catalog

ID	Business rule	Module	Nhãn
BR-009	Tham số ảnh hưởng tiền có ngày hiệu lực ⩾ business date + 1; không tính lại giao dịch đã ghi; thuế của một dòng phí theo TaxRule hiệu lực tại business date ghi dòng đó.	CFG, INV	[A]
BR-019	Phòng có cha hoặc có con phải được gán ngay khi giữ tồn; khi giữ, cập nhật bộ đếm của mọi loại phòng bị ảnh hưởng trong cùng giao dịch.	ROOM, BOOK	[Q] – OQ-001
BR-068	Yêu cầu duyệt khoá giá trị và version đối tượng lúc tạo; đối tượng đã đổi khi duyệt xong thì không thực thi (Failed); quá hạn thì Expired.	RBAC	[A] – OQ-042
BR-069	Đối tượng thuộc cơ sở người dùng không được gán được trả về như không tồn tại; lần truy cập đó được ghi log.	RBAC, AUD	[A]

10.3 Câu hỏi mở mới

ID	Câu hỏi	Hỏi ai	Mức độ	Giả định tạm
OQ-041	Một nhân viên có làm việc ở nhiều cơ sở với vai trò khác nhau không?	SH-01	Medium	Có; một tài khoản, chọn cơ sở đang làm việc

ID	Câu hỏi	Hỏi ai	Mức độ	Giả định tạm
OQ-042	Yêu cầu duyệt hết hạn sau bao lâu?	SH-01, SH-02	Medium	30 phút
OQ-043	2FA bằng ứng dụng xác thực hay OTP qua SMS/Zalo? Ai trả phí OTP?	SH-01, SH-07	High	Ứng dụng xác thực (TOTP) + mã dự phòng
OQ-044	Mỗi cơ sở có máy quầy cố định không? Nhân viên dùng điện thoại cá nhân đến mức nào?	SH-02	Medium	Có ít nhất 1 máy quầy đăng ký; PIN 6 số
OQ-045	Ai được xem đầy đủ giấy tờ tùy thân của khách?	SH-01 + luật sư	High	OWN, MGR, FD, NA (bảng 7.2)
OQ-046	Kế toán có chấp nhận số phiếu thu nhảy số khi giao dịch lỗi không?	SH-04	Medium	Không; cấp số tuần tự trong giao dịch

10.4 Truy vết đợt 1

Business goal	FR	User story	Test case
BG-02 Kiểm soát dòng tiền	FR-CFG-004, 005, 006, 012	US-CFG-001, US-CFG-004	TC-CFG-001 đến 003, TC-CFG-007
BG-06 Quản trị nhiều cơ sở	FR-CFG-001, FR-PROP-001 đến 008, FR-EMP-009	US-CFG-002, US-PROP-001, 002, US-EMP-003	TC-CFG-004, TC-PROP-001 đến 006, TC-EMP-006
BG-01 Loại bỏ double booking	FR-ROOM-004 đến 006	US-ROOM-001, 002, 003	TC-ROOM-001 đến 007
BG-07 Truy vết và chống gian lận	FR-RBAC-001 đến 012, FR-EMP-001 đến 007, FR-AUD-001 đến 008, FR-CFG-007, 011	US-RBAC-001 đến 005, US-EMP-001, 002, US-AUD-001 đến 003, US-CFG-003	TC-RBAC-001 đến 010, TC-EMP-001 đến 008, TC-AUD-001 đến 006, TC-CFG-005, 006
BG-08 Tuân thủ pháp lý	FR-PROP-001, FR-AUD-004, 009, FR-EMP-008	US-AUD-003	TC-AUD-004

10.5 Việc cần làm tiếp

- Đưa BR-009, BR-019, BR-068, BR-069 và OQ-041 đến OQ-046 vào Phần 1 sau khi PO đồng ý.
- Review Phần 2 với Dev Lead (Data Dictionary, NFR) và Owner (ma trận quyền, ngưỡng).
- Bắt đầu đợt 2 ("Từ liên hệ đến đủ cọc"): RATE, BOOK, CAL, GST, PAY (cọc), INV (folio).